



Criptografía y Seguridad

Seguridad en
aplicaciones:
Flujo de información

El problema...

Una política de seguridad dice:

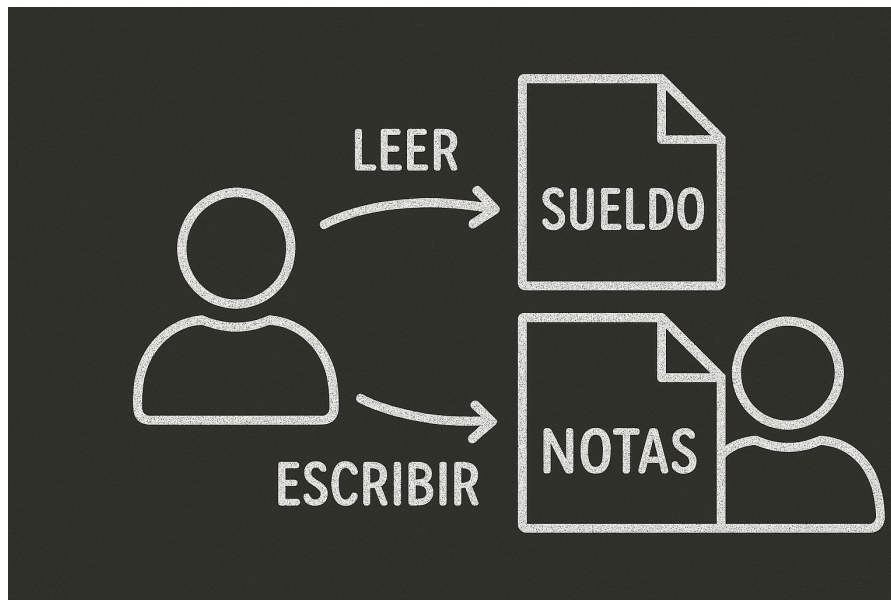
Un empleado no puede ver los sueldos de otros empleados.

Como podemos implementar esto?

El problema...

Una política de seguridad dice:

Un empleado no puede ver los sueldos de otros empleados.



Control de acceso no impide copiar la información a otro lugar

Control de acceso vs flujo

Control de acceso

Limita acceso a operaciones sobre objetos

Los objetos contienen información

Limita el acceso a información

Pero

La información no es estática

Es actualizada

Puede copiarse

Políticas y Control de Acceso

Las políticas, por lo general restringen el flujo de información y no el acceso a objetos

Comparar:

Evitar que un empleado sepa el sueldo de otro

Vs

Evitar que un empleado acceda a la base de datos de sueldos

¿Entonces los controles de acceso no sirven?

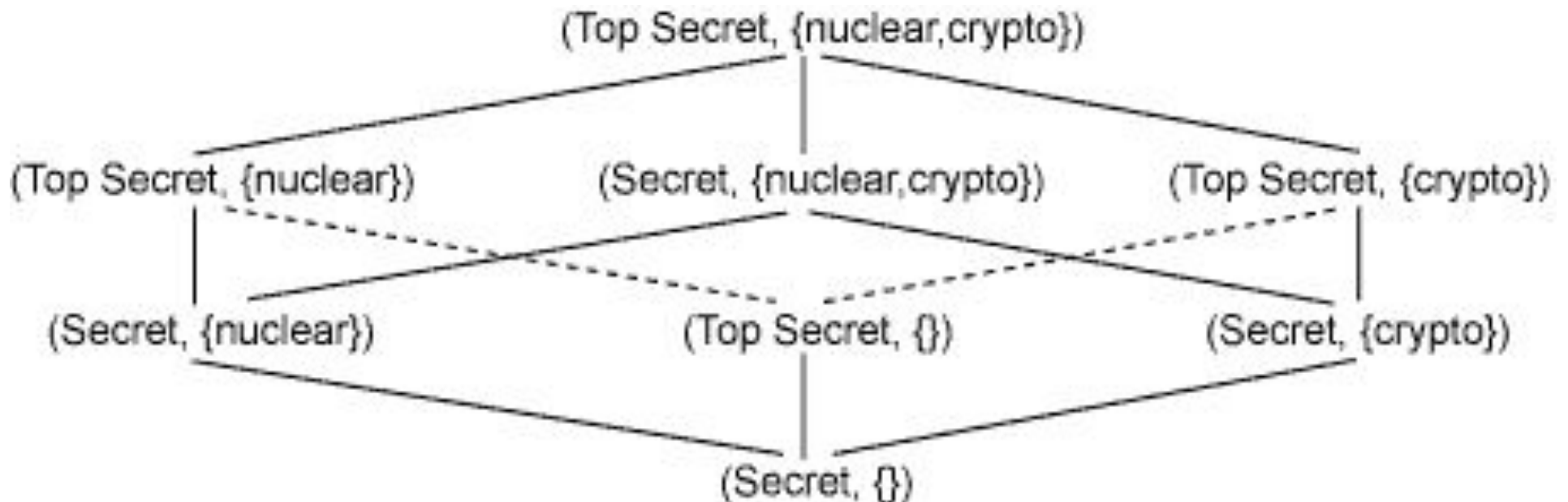
Sirven, pero por lo general son mecanismos abiertos.

Deben ser complementados

El problema del confinamiento

Si se pudiera confinar el flujo de información dentro de un ambiente controlado, no habría riesgos de confidencialidad o integridad.

El modelo Bell-Lapadula define un modelo de seguridad para asegurar el confinamiento.



El problema del confinamiento

El problema del confinamiento (de acceso) se refiere a la dificultad de asegurar que un programa o proceso (denominado "sujeto") no transmita información a otra entidad (denominada "objeto") a la que no está autorizado a acceder, ya sea de manera directa o indirecta.

Modelo ideal: Aislación total

Requisitos:

Un proceso no puede comunicarse con otros procesos

Un proceso no puede ser observado

Consecuencias:

El proceso no revela información

En la práctica, los procesos usan recursos observables:

Memoria

Ciclos de CPU

Espacio en disco

Ancho de banda

Covert Channel

Un canal encubierto (covert channel) es un método de comunicación utilizado para transferir información de manera oculta, aprovechando vías no diseñadas para la transmisión de datos.

En el contexto de la seguridad de la información, los canales encubiertos son utilizados para evitar los controles de seguridad y transmitir datos sin detección.

Covert Channel

Canales de Temporización (Timing Channels):

Estos canales utilizan la temporización del sistema para transmitir información. La idea es codificar datos en la variación del tiempo entre eventos.

Latencia de Red

Carga de CPU

Tiempos de Respuesta de Aplicaciones

Covert Channel

Canales de Almacenamiento (Storage Channels):

Estos canales utilizan el almacenamiento de información en áreas no convencionales o no reguladas del sistema para transmitir datos.

Espacio en Archivo: Utilizar bits no utilizados en los archivos (por ejemplo, en el espacio de relleno de un archivo) para almacenar y luego leer información secreta.

Atributos de Archivos: Modificar atributos de archivos como la fecha de creación, modificación o acceso.

Bits no Usados en Estructuras de Datos

Ejemplos: Covert Channel

Exfiltración de información codificando sonidos en el proceso de impresión.

<https://dl.acm.org/doi/10.1145/3510583>

ICMP & DNS Tunneling.

<https://www.akamai.com/blog/news/introduction-to-dns-data-exfiltration>

Emanaciones electromagnéticas

Side-Channel Attack

Ataque de Canal Lateral (Side Channel Attack):

Un ataque de canal lateral explota las emisiones físicas y temporales de un sistema para extraer información sensible.

No se basa en vulnerabilidades clásicas del software o errores de autenticación, sino en la observación de efectos colaterales del hardware durante su funcionamiento.

Es especialmente relevante en criptografía, donde un atacante podría medir tiempos de ejecución, consumo de energía, radiación electromagnética o incluso ruido acústico para inferir claves de cifrado u otra información crítica.

Ejemplos: Side-Channel Attack

Los atacantes miden el tiempo que toma para ejecutar operaciones criptográficas y utilizan esta información para inferir claves secretas.

https://link.springer.com/chapter/10.1007/3-540-68697-5_9#preview

Analizan el consumo de energía de un dispositivo durante las operaciones criptográficas para obtener información secreta.

https://link.springer.com/chapter/10.1007/3-540-48405-1_25

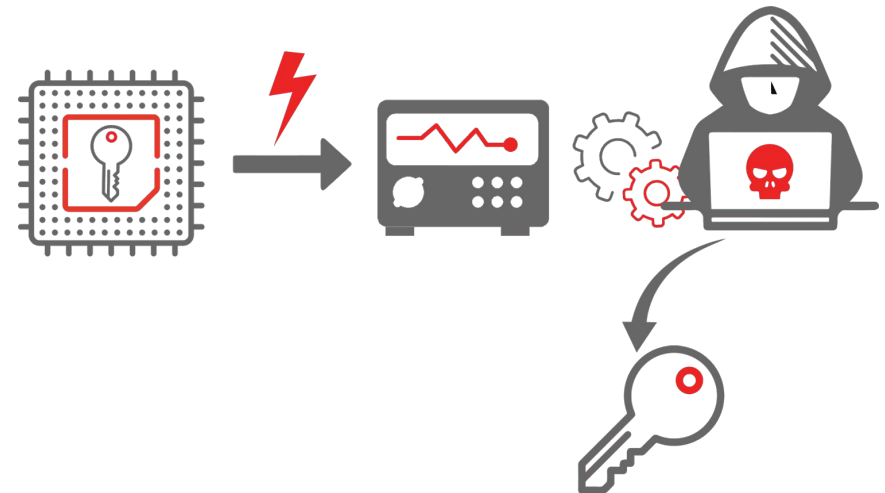
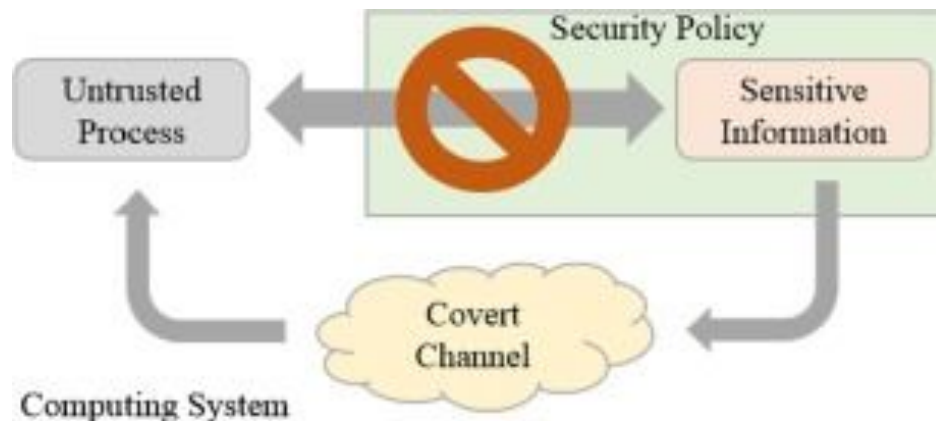
Utilizan emisiones de radiación electromagnética para obtener información sobre la operación interna de un dispositivo, incluyendo sus claves secretas.

<https://dl.acm.org/doi/10.5555/648254.752700>

Comparación

Canal Encubierto: Se centra en evadir controles de seguridad para transmitir información dentro y fuera de un sistema de manera oculta.

Ataque de Canal Lateral: Se enfoca en recolectar información sensible mediante la observación del comportamiento físico del hardware durante su operación.



Control de flujo

Tiempo de compilación (compile-time enforcement)

Analiza propagación de información directamente en el código fuente

Costoso y complejo → Limitado a componentes muy sensibles

Tiempo de ejecución (run-time enforcement)

Control dinámico (sandboxing)

Aislación (virtualization)

Son los métodos más utilizados



Criptografía y Seguridad

Control de flujo en
tiempo de
compilación

Concepto

Cuantificar la información asociada a cada variable

Evaluar cómo cambia la información asociada en cada sentencia

Comparar el valor inicial y final de cada variable

Los cambios indican transferencia de información

Si hay transferencia que no debiera ocurrir, fallar.

Entropía como medida de información

Definida sobre una variable aleatoria discreta

Sea X una V.A.D. Que toma valores $x_1 \dots x_n$

$$H(X) = - \sum_{i=1}^n p(x_i) \log p(x_i)$$

Mide incertidumbre a la hora de determinar el valor de una variable

Máximo: $p(x_i) = 1/n$

Distribución uniforme

Mínimo: $p(x_i) = 1, p(x_j) = 0$ para $j \neq i$

Evento único

Entropía condicional

Sea X una V.A.D. Que toma valores $x_1 \dots x_n$

Sea Y una V.A.D. Que toma valores $y_1 \dots y_m$

$$H(X | Y = y) = - \sum_{i=1}^n p(x_i | y) \log p(x_i | y)$$

$$H(X | Y) = \sum_{j=1}^m p(y_j) H(X | Y = y_j)$$

Flujo de información: Definición

Sea s el estado de un sistema

Sea t el estado del sistema luego de ejecutar comandos $c_1, \dots, c_n$

Sean x_s, y_s valores de objetos en el estado s

Sea y_t valor de y en el estado t

Hay flujo de información de x a y si:

$H(x_s | y_t) < H(x_s | y_s)$, si y existe en el estado s

$H(x_s | y_t) < H(x_s)$, si y no existe en el estado s

Seguimiento de flujo de información

Existen técnicas formales de análisis de flujo de información en programas.

En general existe flujo de información en un programa.

Es necesario para funcionar

A veces interesa verificar casos puntuales

Que una función de cifrado no revele información de la clave

Flujo directo

Considerar el comando:

$$y = x + z$$

Donde

$0 \leq x \leq 7$, con igual probabilidad

$$Z = \{ p(z=1)=0.5, p(z=2)=0.25, p(z=3)=0.25 \}$$

Entonces

$$H(x) = -8 \sum (1/8 \lg (1/8)) = 3$$

Hay traspaso de
información de x a y!

Conociendo y luego del comando

x puede tener solo 3 valores (y-1, y-2, y-3)

$$H(x | y) = -(1/2) \lg (1/2) - 2(1/4) \lg (1/4) = 1.5$$

Flujo indirecto

La información puede fluir de manera indirecta

Ejemplo:

If $(x == 0)$ $y = 1$ else $y = 0$

x e y no aparecen en la misma asignación

Considerar x como $\{0,1\}$ con $p(x=0) = 0.5$

$$H(x) = 1$$

$$H(x | y) = 0$$

Hay traspaso de información!

Flujo indirecto

La información puede fluir por comportamiento

Ejemplo:

```
while (x = 0) {}
```

No existe ninguna asignación

Considerar x como $\{0,1\}$ con $p(x=0) = 0.5$

Definir $y = 0$ si el programa termina

$$H(x) = 1$$

$$H(x | y) = 0$$

Hay traspaso de información!

Límites

Estas técnicas comparten los límites de la verificación formal:

No es computable verificar todo programa

Cuando hay interactividad los casos explotan en cantidad

Los ciclos son un problema



Criptografía y Seguridad

Control de flujo en
tiempo de ejecución

Aislamiento

Los sistemas aíslan procesos de dos maneras:

Ambiente de ejecución sintético separado del real, y aislado por definición (virtualización)

Control y modificación de las interacciones del sistema con su entorno (sandboxing)

Aislamiento (Virtualization)

Virtual Machines

Las máquinas virtuales (VMs) usan hipervisores para emular hardware y gestionar diferentes sistemas operativos en un solo host físico.

Los hipervisores pueden ser de tipo:

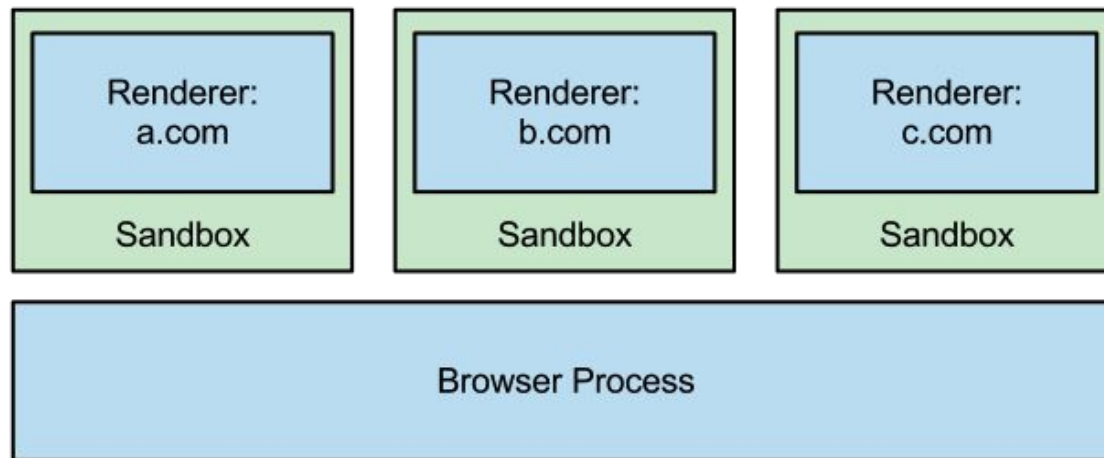
- Bare-metal, como KVM, VMware ESXi o Hyper-V,

- Hosted, como VirtualBox o VMware Workstation.

Las VMs tienen su propio kernel, lo que proporciona fuerte aislamiento entre ellas.

Aislamiento (Sandboxing)

Se basa en analizar las interacciones de un proceso con su ambiente y las modifica para aislarlo



Aislamiento (Sandboxing)

Al nivel sistema operativo:

Linux

Namespaces: permiten aislar procesos y recursos.

Permite aislar procesos, usuarios, red, filesystem, y más.

cgroups: controlan y limitan el uso de recursos como CPU, memoria y red para diferentes procesos.

Windows

User Mode Scheduling: Similar a namespaces en Linux.

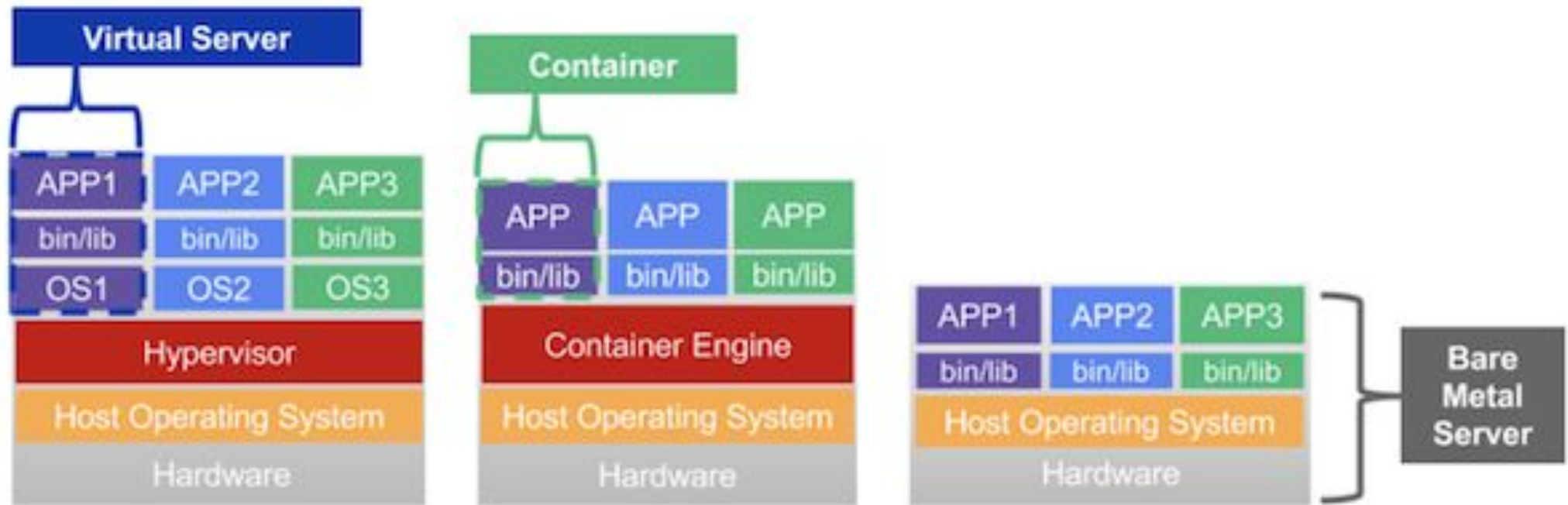
Job Objects: Permiten gestionar grupos de procesos como una unidad. Esto se utiliza para asignar límites de recursos y prioridades a estos grupos.

Aislamiento (Sandboxing)

Contenedores

Los contenedores aprovechan tecnologías como namespaces y cgroups en Linux (Docker es un ejemplo popular) para aislar aplicaciones, permitiendo que múltiples contenedores compartan el mismo kernel del SO anfitrión pero manteniendo la separación lógica en términos de red, procesos y sistema de archivos. Windows soporta contenedores nativos que usan características de windows o Hyper-V.

Aislamiento (Sandboxing)



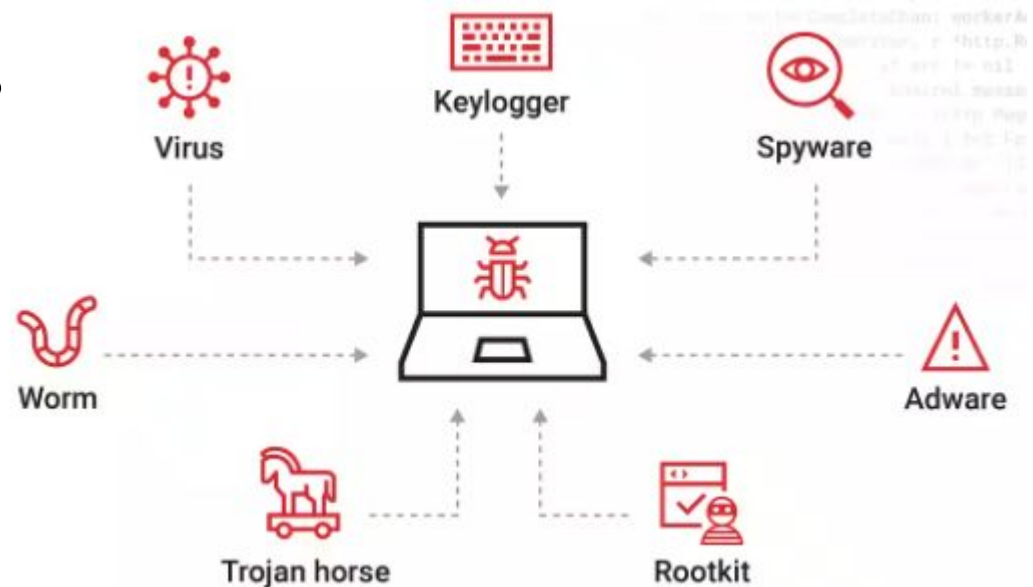


Criptografía y Seguridad

Malware

Malware

- Malicious Software, o Malware es el término con el que se identifica a cualquier programa diseñado para causar daño, atravesar un control o extraer información.
- Un ataque usualmente usa múltiples tipos de malware para ejecutar cada parte del ciclo del ataque.
- El malware suele aprovechar vulnerabilidades del software para lograr su cometido.



Tipos de Malware

- Virus/Worm

- Posee la característica infectar una máquina y usar los medios disponibles para propagarse entre máquinas.
- Puede infectar directamente una máquina por medio de una explotación de una vulnerabilidad remota o infectar algún recurso compartido (archivos).
- Worm, se especializa en la infección por medio de la red, propagándose inclusive por email (Melissa 1999).
- SQL Slammer infectó 75000 computadoras en 10 minutos gracias a las bases de datos SQL expuestas a internet.

Tipos de Malware

- Troyano

- Malware oculto dentro de otro software que parece benigno y de interés para la víctima.
- Se utiliza para establecer al atacante dentro del equipo infectado.
- PC-Write (1986), fue uno de los primeros sharewares que ofrecía un editor de texto, y contenía un troyano que borraba todos los archivos de la máquina.

Tipos de Malware

- Rootkit

- Software diseñado para ocultar malware dentro de la máquina infectada.
- Utiliza técnicas de ofuscación, encriptación, reescritura y reemplazo de herramientas del sistema para quedar oculto a los administradores y antivirus.
- Pueden operar a nivel de kernel o de usuario.
- NTRootkit (1999) fue el primer rootkit para Windows NT.
- Stuxnet (2010) utilizó rootkit para recolectar por meses información antes lanzar el ataque que afectó las plantas nucleares de Irán.

Tipos de Malware

- Spyware

- Software diseñado para recolectar información del usuario infectado.
- Se especializa en el ocultamiento de información dentro del activo infectado y usualmente establece alguna forma de covert channel (túnel).
- Algunas empresas desarrollan este software a pedido de los gobiernos para hacer vigilancia digital o espionaje.

Tipos de Malware

- Ransomware

- Software diseñado para bloquear el acceso de los usuarios a su información, pidiendo dinero para volver a restaurar el acceso.
- CryptoLocker (2013), enviado vía mail, infectaba a los usuarios al abrir el correo. Se estima que se robaron cerca de U\$D 3M en ese año.
- Wannacry (2017), aprovechando una vulnerabilidad de Windows conocida fue uno de los primeros ransomwares en distribuirse en la red local. Se estima que la infección de mas de 200K máquina, tuvo un costo de U\$D 4B.

Tipos de Malware

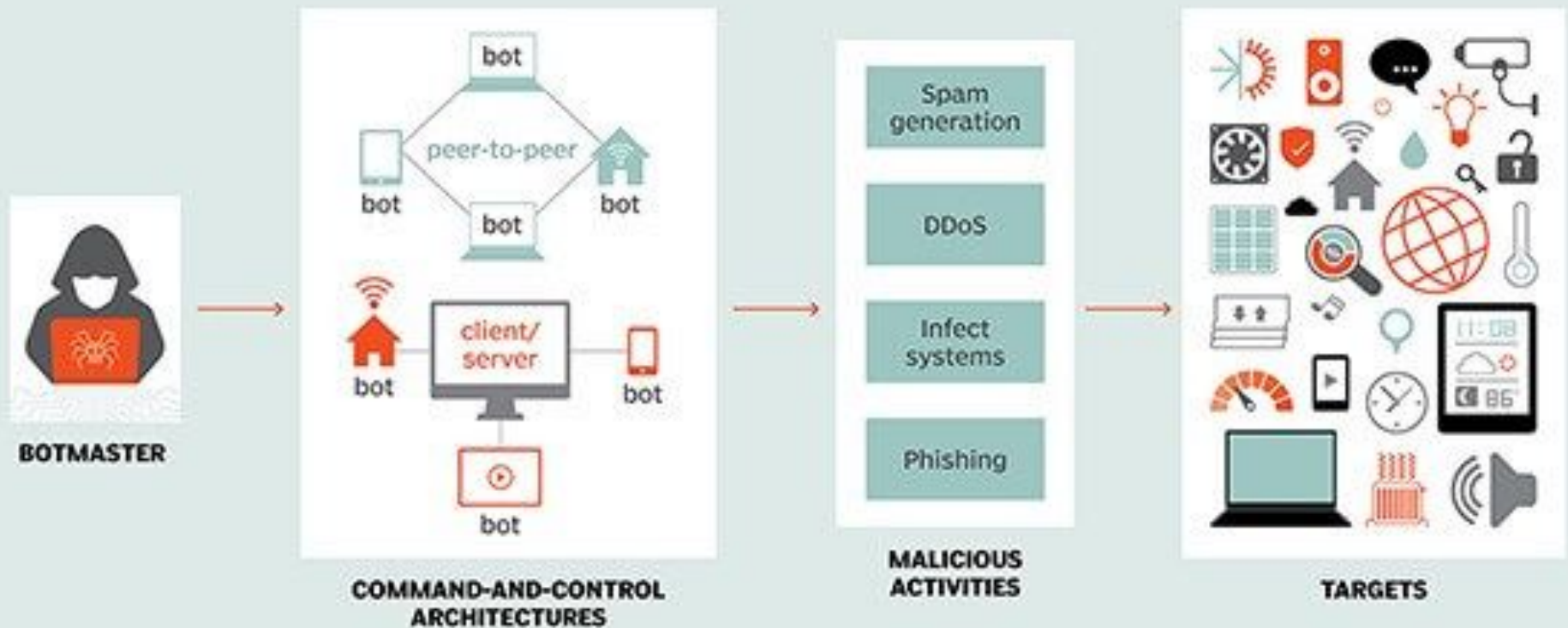
- Botnet

- Software diseñado para desplegar bots o agentes multiuso que permanecen a la escucha de instrucciones.
- Las máquinas infectadas se usan para disparar ataques distribuidos, minería de cripto, accesos anónimos, distribuir spam, entre otros usos maliciosos.
- Srizbi BotNet (2008) se considera la botnet más grande que existió. Se estima que fue responsable por el envío de la mitad del spam mundial (60B mails por días).

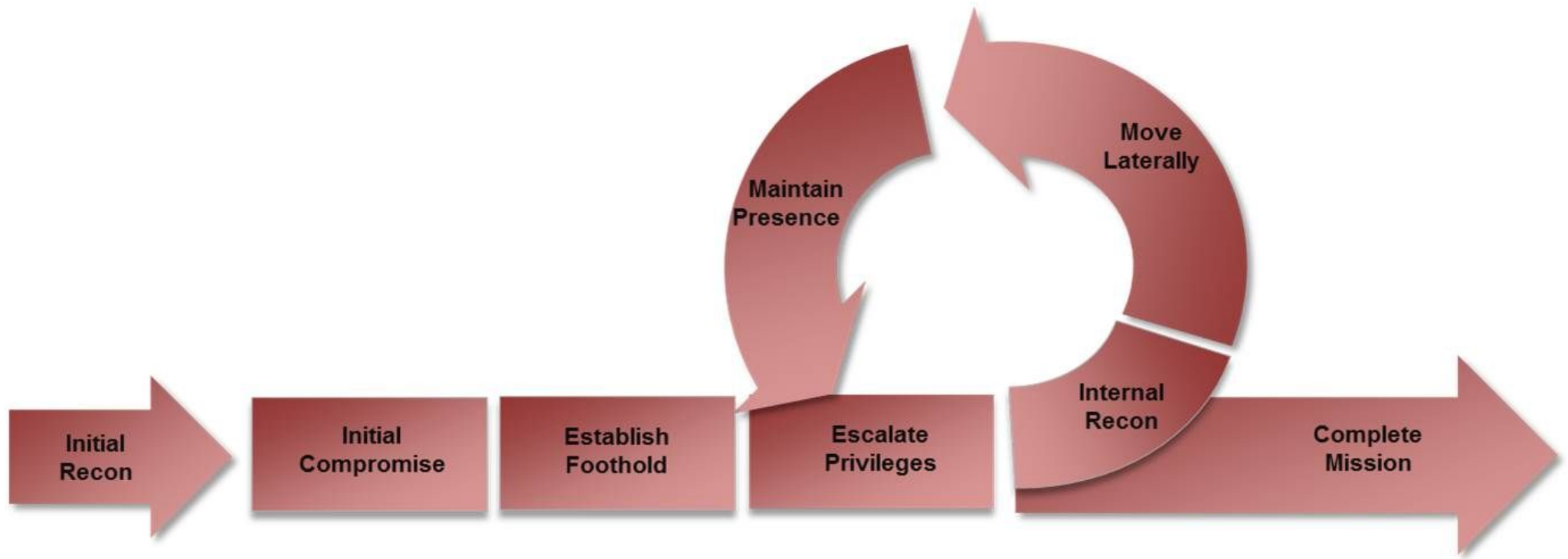
Tipos de Malware

- Botnet

Botnet Architecture

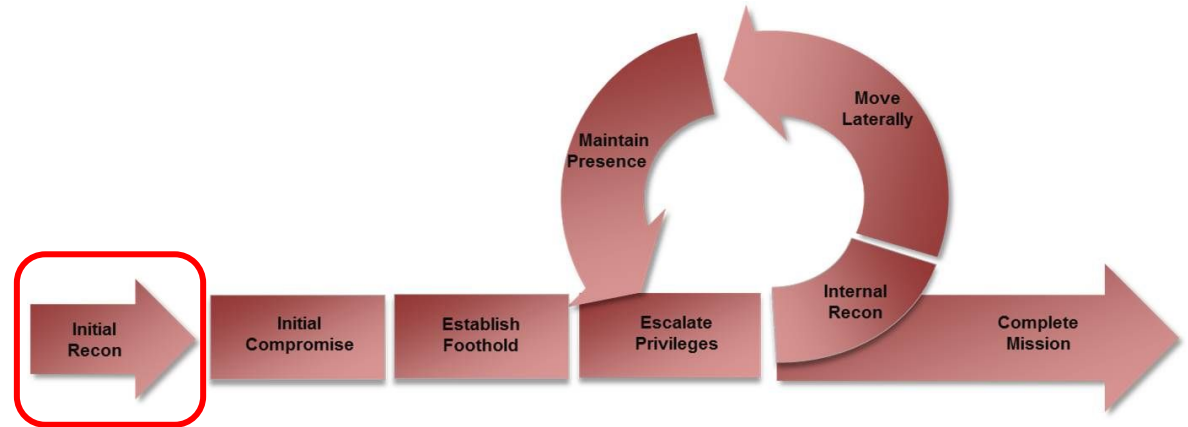


Malware attack cycle



Malware attack cycle - Recon

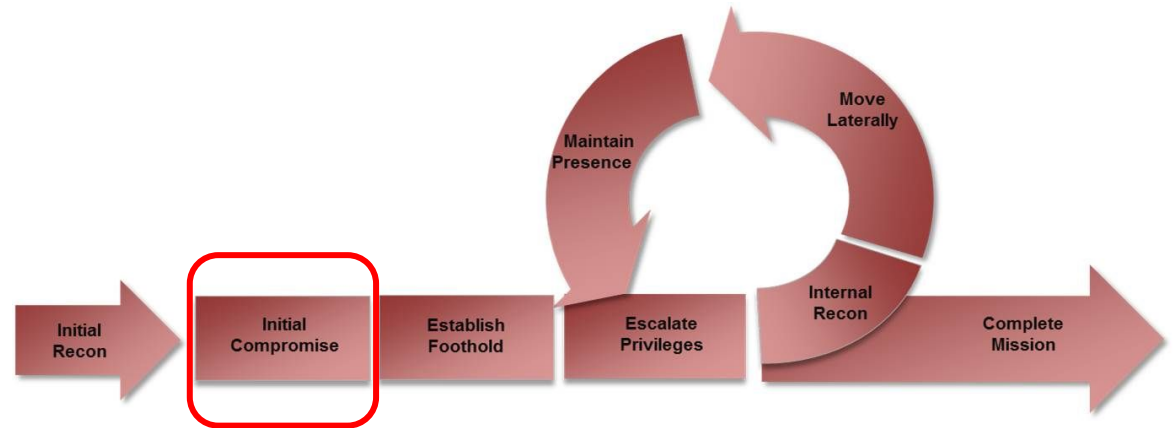
Reconocimiento Inicial



- Se identifica a la víctima y se recopila información.
- Se explora toda la información interna, responsables, puntos débiles.
- Se exploran intereses y afinidades de los responsables en las posiciones claves.
- Identifican redes sociales de los empleados y se establecen relaciones falsas.

Malware attack cycle - Initial Compromise

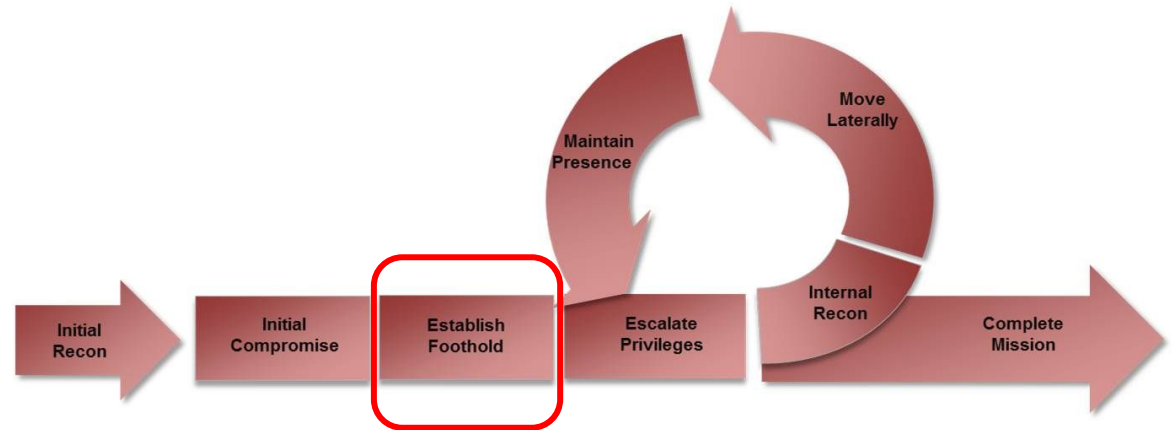
Compromiso inicial



- El malware de “*Weaponiza*” y se empaqueta de forma que pueda ser ejecutado por la víctima.
- Usando alguna forma de ataque dirigido se compromete una o más máquinas.
- Este proceso puede durar varios días hasta lograr la primera infección.

Malware attack cycle - Initial Compromise

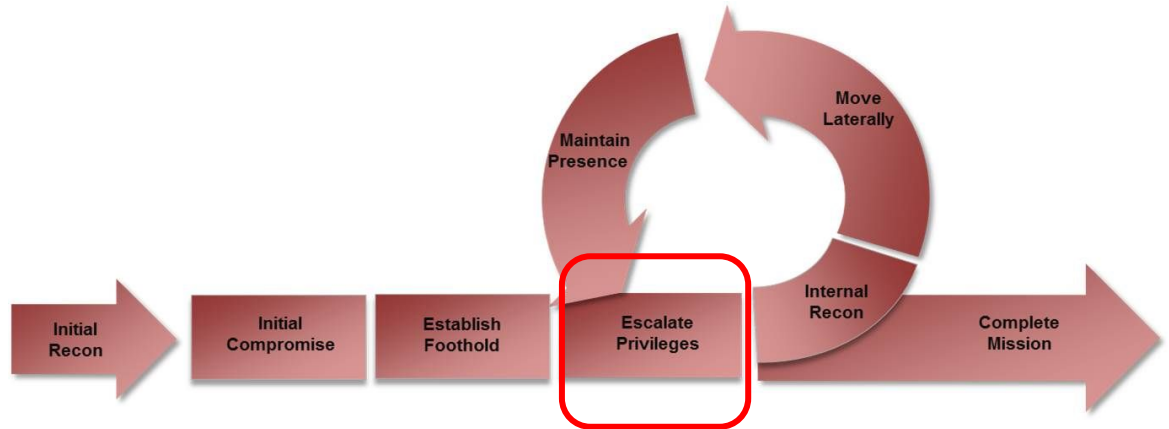
Establecerse



- El malware trata de establecer comunicación hacia su comando y control (C&C), asegurarse la persistencia y almacenamiento seguro
- Se bajan y componen las nuevas herramientas que se van a utilizar en las etapas posteriores.
- Esta etapa suele durar minutos después de la infección inicial.

Malware attack cycle - Initial Compromise

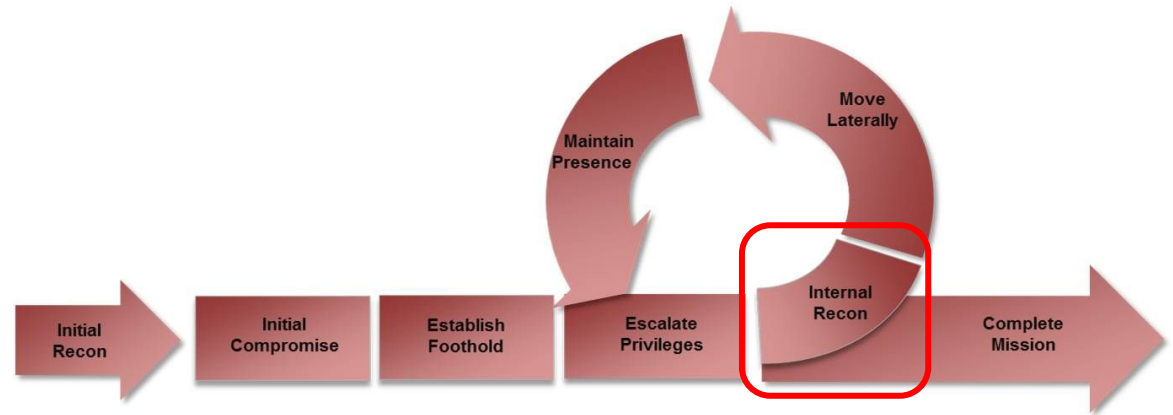
Escalamiento de privilegios



- En esta etapa el malware trata de elevar los privilegios inicialmente obtenidos.
- Puede utilizar vulnerabilidades locales o remotas.
- Este proceso suele durar minutos.

Malware attack cycle - Initial Compromise

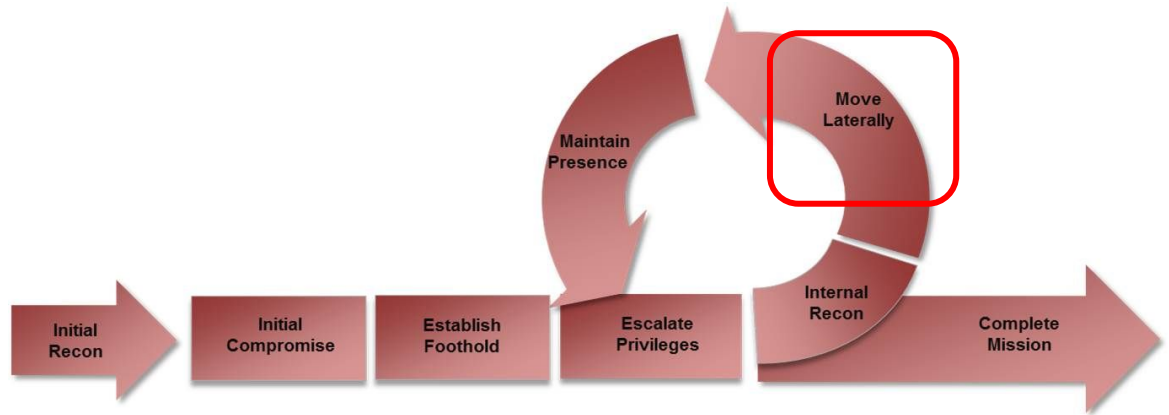
Reconocimiento
interno



- El malware hace análisis de comunicaciones y va mapeando otras posibles máquinas o usuarios de interés.
- Se prueba comunicación y visibilidad desde las máquinas infectadas.
- Del descubrimiento se bajan y componen nuevos malwares.

Malware attack cycle - Initial Compromise

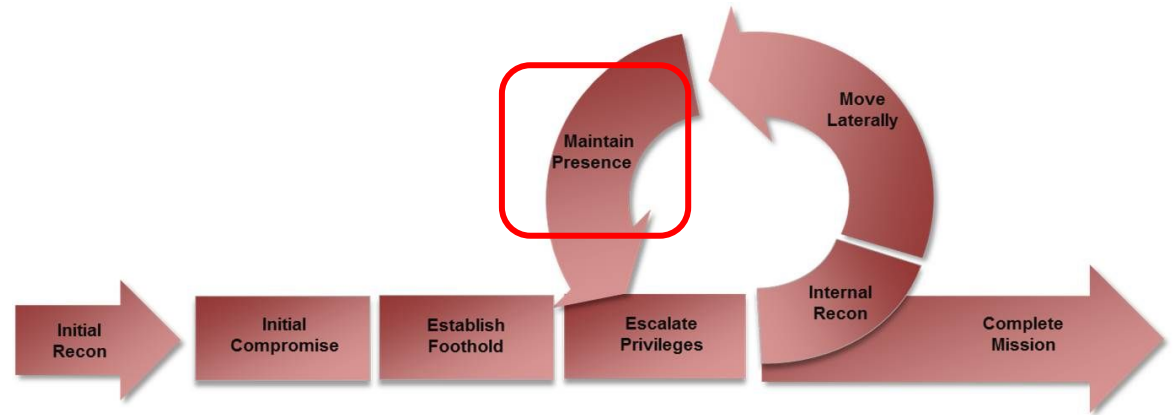
Movimiento Lateral



- El malware realiza explotación remota de vulnerabilidades y busca incrementar la base infectada.

Malware attack cycle - Initial Compromise

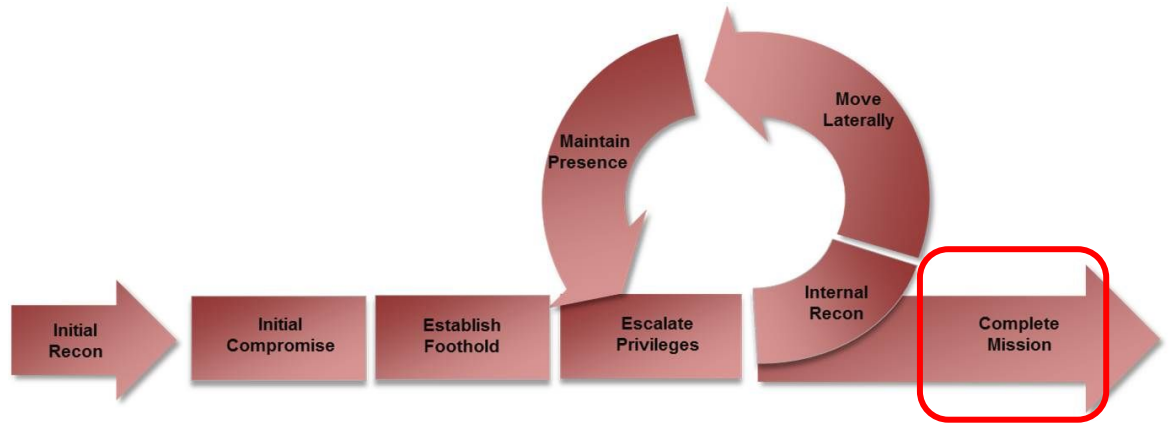
Mantener la persistencia



- El malware se asegura persistir en las nuevas máquinas infectadas.

Malware attack cycle - Initial Compromise

Mantener la persistencia



- Cuando el atacante ya tiene acceso a los datos de interés, va extrayendo la información o la acumula internamente hasta enviarla hacia afuera en horarios con menor monitoreo.
- En el caso del ransomware, se infectan la mayor cantidad de máquinas posible antes de activar el bloqueo a los datos.

Lectura recomendada

Capítulo 16-1

Capítulo 17

Computer Security Art and Science

Matt Bishop